QR Code Identity Forgery Vulnerability Report

1. Executive Summary

This vulnerability exists in an identity verification system that grants access based on cryptographic badges encoded in QR codes. The system verifies badge JSON schema but does not validate that the badge was actually issued by a trusted authority.

2. Vulnerability Description

The system accepts any QR code that contains a JSON object matching the required schema, with no cryptographic signature or issuer validation. An attacker can generate a fully valid admin-level badge locally and present it for verification.

3. Exploitation Methodology

1. Extract the required badge JSON schema by asking the system what fields are needed for admin access.
2. Locally generate a QR code containing a valid admin-level JSON object matching the schema.
3. Present the forged QR code to the verification system. The system validates the schema and grants full admin access.

4. Impact

This allows any attacker to forge a highest-privilege admin badge and bypass all identity verification, gaining unrestricted access to protected systems.

5. Remediation Recommendations

Add cryptographic signature verification for all badges, so only badges signed by the trusted internal certificate authority are accepted. Do not rely solely on JSON schema validation, as schema alone cannot prove badge authenticity.